

What is Cross Site Request Forgery (CSRF)?

- CSRF is a web attack where a hacker tricks a logged-in user into performing an action they never intended.
- The attack forces the victim's browser to send unauthorized requests to a website where they are already authenticated.
- The browser automatically sends cookies, session IDs, authentication tokens, so the request looks legitimate to the server.

How Attackers Perform CSRF

- Attacker finds a sensitive action
- Attacker creates a malicious link, form, or image tag
- Victim must be logged in to the target website.
- Victim clicks attacker's link OR visits attacker's page.
- Browser automatically sends cookies/session, so the action executes.

Impact of CSRF Attacks

- Unauthorized money transfers
- Password/email changes
- Account deletion
- Posting content without permission
- Purchases made on user's behalf
- Changing admin settings (if target is admin)

This makes CSRF extremely dangerous because:

- No code runs on victim's browser (unlike XSS).
- It uses trust between browser and website.

How to Prevent CSRF

- Anti-CSRF Tokens (Most Important + Industry Standard)
- SameSite Cookies
- Re-authentication for Critical Actions
- CAPTCHA
- Avoid Using GET Requests for Sensitive Actions

Important Points

- CSRF works only if the victim is logged in.
- CSRF does not rely on JavaScript → even HTML `<img>` tag can trigger it.
- XSS can be used to bypass CSRF protections.
- CSRF is called a "confused deputy problem" — the browser becomes a weapon.